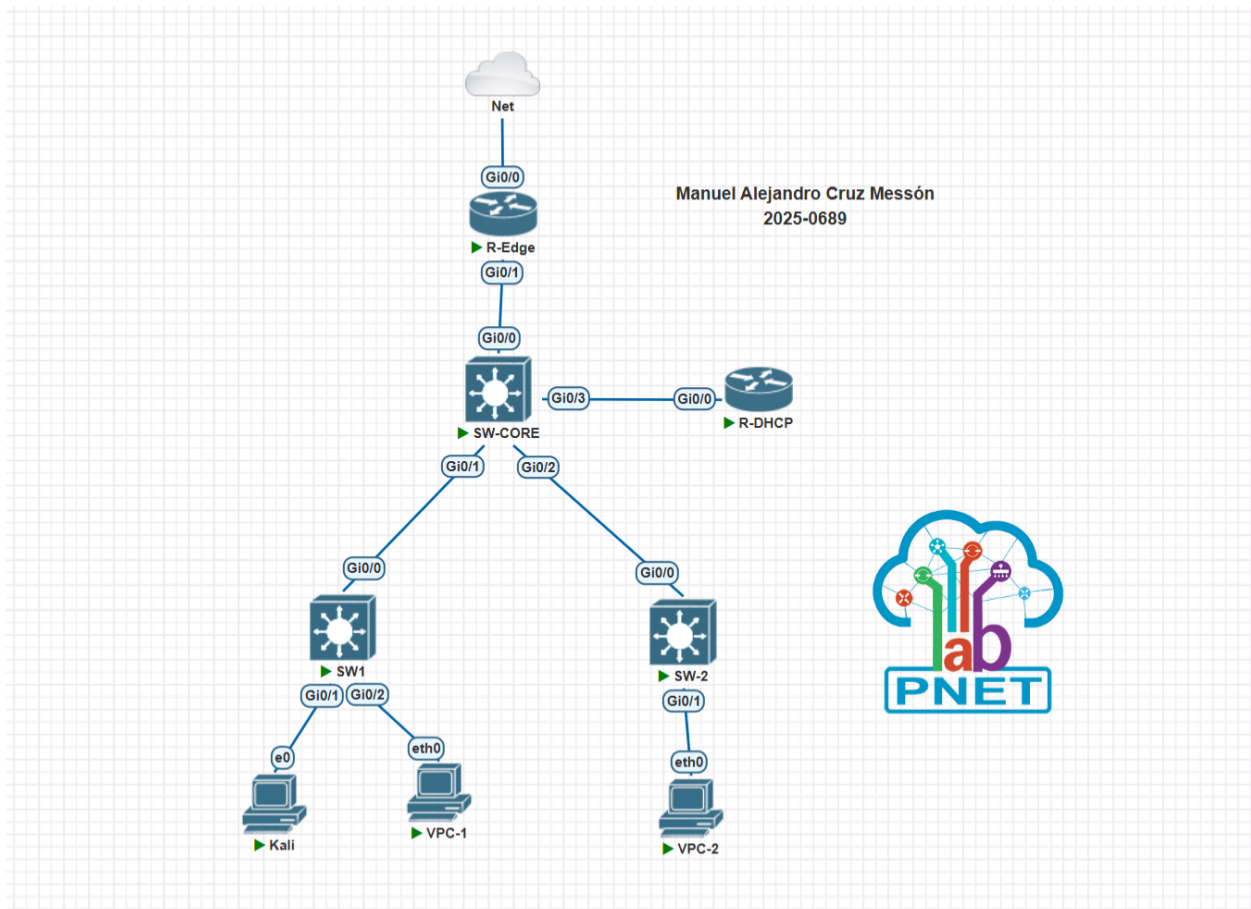


Ataque DHCP Starvation

1. Objetivo del Laboratorio

El objetivo fundamental de este laboratorio es demostrar de forma práctica y controlada un ataque de denegación de servicio (DoS) a la capa de infraestructura local mediante el agotamiento del direccionamiento IP (DHCP Starvation). El ejercicio busca simular un escenario de ataque coordinado en dos fases: en primer lugar, se desactiva el servidor DHCP legítimo (en este caso, un dispositivo vIOS) consumiendo todo su espacio de direcciones disponibles; en segundo lugar, se prepara el entorno para obligar a los nuevos clientes de la red a utilizar un servidor DHCP malicioso (Rogue DHCP Server), consolidando una posición de Hombre en el Medio (MitM).

2 | Topología de la Red



La topología representa una red de laboratorio estructurada bajo una arquitectura jerárquica simple, donde todos los dispositivos internos coexisten en la VLAN 89. La red cuenta con servicios automáticos de asignación de direccionamiento IP (DHCP) administrados por un enrutador dedicado, y salida a redes externas (Internet) a través de un enrutador de borde con traducción de direcciones.

A. Hardware y Dispositivos

La infraestructura física y los nodos que componen la topología se distribuyen según sus roles funcionales en la red:

1. Dispositivos de Enrutamiento (Capa 3):

- R-Edge: Enrutador de borde perimetral encargado de la salida a redes externas.
- R-DHCP: Enrutador dedicado exclusivamente a la administración y distribución de direccionamiento IP dinámico en la red local.

2. Dispositivos de Conmutación (Capa 2):

- SW-CORE: Switch central (Núcleo) que interconecta los enrutadores y distribuye el tráfico hacia los switches de acceso.
- SW-1 y SW-2: Switches de acceso encargados de proveer conectividad directa a los nodos finales.

3. Dispositivos Finales (Hosts):

- Kali: Estación de trabajo orientada del atacante.
- VPC-1 y VPC-2: Computadoras virtuales de escritorio (Virtual PCs) que actúan como usuarios finales de la red.
- Net: Nube que simula el entorno de red externa o Internet.
-

B. Componentes de Software

Entorno lógico y sistemas operativos que corren sobre la infraestructura:

- **Sistemas Operativos de Red:** Software basado en emulación de Cisco (IOS) para la gestión y ejecución de protocolos de red (CDP, DHCP, NAT, Routing) en los routers y switches.
- **Sistemas Operativos de Hosts:**
 - Kali Linux instalado en la estación atacante.
 - OS ligero (VPCS) en las terminales de usuario para pruebas de conectividad básica (Ping, Traceroute).

C. Segmentación y Parámetros de Red

Definición del direccionamiento lógico, segmentación LAN y salida a Internet:

1. **Segmento de Red Interno:** 192.168.89.0/24 (Máscara de subred 255.255.255.0).
2. **VLAN Configurada:** VLAN 89, segmento único donde coexisten de forma nativa todos los dispositivos internos, switches (vía SVI) y routers.
3. **Puerta de Enlace (Default Gateway):** 192.168.89.254 (Configurada en la interfaz Gi0/1 de R-Edge). Es el nodo encargado de recibir todo el tráfico interno con destino externo y realizar NAT/PAT para darle salida hacia Internet.

D. Interfaces Utilizadas

Dispositivo Origen	Interfaz Local	Dispositivo Destino	Interfaz Remota
R-Edge	Gi0/0	Net (Nube)	—
	Gi0/1	SW-CORE	Gi0/0
R-DHCP	Gi0/0	SW-CORE	Gi0/3
SW-CORE	Gi0/0	R-Edge	Gi0/1
	Gi0/3	R-DHCP	Gi0/0
	Gi0/1	SW1	Gi0/0
	Gi0/2	SW2	Gi0/0
SW-1	Gi0/0	SW-CORE	Gi0/1
	Gi0/1	Kali	e0
	Gi0/2	VPC-1	eth0
SW-2	Gi0/0	SW-CORE	Gi0/2
	Gi0/1	VPC-2	eth0
Kali	e0	SW1	Gi0/1
VPC-1	eth0	SW1	Gi0/2
VPC-2	eth0	SW2	Gi0/1

2. Objetivo del Script

El script `dhcp-starvationn.py` es una herramienta de automatización basada en Scapy diseñada para agotar un segmento específico de direcciones IP de manera inteligente y bidireccional. Sus objetivos técnicos son:

4. **Simulación de Clientes Masivos:** Generar de forma masiva peticiones DHCP con identidades físicas (MAC) y números de transacción (XID) completamente aleatorios y únicos.
5. **Agotamiento del Pool Específico:** Consumir de forma exclusiva el rango asignado al enrutador o servidor legítimo (rango 192.168.89.1 al 192.168.89.149).
6. **Consolidación del Lease (Ataque Inteligente):** A diferencia de las herramientas que solo inundan la red con paquetes Discover (dejando los direccionamientos en estado de reserva temporal), este script escucha las ofertas (Offers) del servidor y completa el proceso de solicitud (Request) para asegurar y "robar" la IP de manera definitiva en la tabla de concesiones (Leases) del servidor DHCP legítimo.

3. Parámetros Usados

El script maneja configuraciones internas fijas y captura variables operativas mediante la línea de comandos empleando el módulo `argparse`:

Parámetros de Consola

- **-i, --interface (Obligatorio):** Define la interfaz de red (por ejemplo, `eth0`, `ens3`) a través de la cual se inyectarán las tramas y se capturarán las respuestas del servidor.

Parámetros Técnicos Internos

- **PACKET_DELAY (0.01s):** Tiempo de espera entre paquetes individuales dentro de una misma ráfaga.
- **BURST_SIZE (10):** Número de paquetes Discover que se envían de forma consecutiva por cada ráfaga.
- **BURST_DELAY (0.1s):** Tiempo de descanso entre ráfagas consecutivas para mitigar saturaciones del canal antes de procesar respuestas.
- **STARVE_IP_START y STARVE_IP_END:** Establecen los límites del direccionamiento IP del servidor legítimo vIOS que serán objeto del ataque de denegación de servicio.

4. Requisitos para Utilizar la Herramienta

Para que el script opere adecuadamente, deben cumplirse las siguientes condiciones en el entorno de pruebas:

- **Privilegios de Superusuario (Root):** Interactúa directamente con la capa física y

de enlace mediante sockets de bajo nivel, lo que exige su ejecución mediante sudo.

- **Sistema Operativo Linux:** La sintaxis y las llamadas del script están ligadas a interfaces de red y dependencias de entornos Linux.
- **Scapy Versión 2.5.0:** Suite de paquetes de red para la correcta manipulación de las capas Ether, IP, UDP, BOOTP y DHCP.
- **Persistencia en la Red:** El script debe permanecer en ejecución continua; si el ataque se detiene, los tiempos de concesión (Lease Time) del servidor legítimo podrían expirar, liberando IPs de vuelta al pool.

5. Documentación del Funcionamiento del Script

El script opera de manera asíncrona mediante el uso de **hilos de ejecución de Python (threading)**, lo que le permite enviar ráfagas de paquetes agresivas mientras procesa y consolida las respuestas del servidor en tiempo real de forma paralela.

Fase 1: Inicialización de los Hilos Secundarios

Al ejecutarse el script, se configuran dos procesos de apoyo en segundo plano:

- **Listener de Respuestas (start_response_listener):** Inicia una captura pasiva (sniff) filtrada bajo el protocolo "udp and port 68". Cada vez que el servidor DHCP legítimo responde, los paquetes son procesados de inmediato por el callback del script.
- **Monitor de Estadísticas (stats_monitor):** Un hilo que cada 5 segundos imprime en pantalla una interfaz textual detallada. Muestra la tasa de paquetes por segundo, el porcentaje de progreso del ataque y la lista de las últimas direcciones físicas falsas creadas que han asegurado con éxito una IP.

Fase 2: Inundación Selectiva (Generación de Discovers)

El hilo principal ejecuta el bucle infinito starvation_loop().

2. Crea una dirección MAC pseudoaleatoria mediante unique_mac(), asegurándose de que no se repita en el historial (used_macs).
3. Genera un número identificador de transacción aleatorio (xid) y mapea la relación en el diccionario global active_xids = { xid: fake_mac }.
4. Ensambla y transmite una trama DHCP DISCOVER enviada a la dirección de difusión total (ff:ff:ff:ff:ff:ff). Repite este paso hasta cumplir el tamaño de ráfaga determinado antes de realizar una pausa controlada.

Fase 3: Captura y Validación de Ofertas (Filtro vIOS)

Cuando el servidor real responde con un paquete DHCP OFFER (Mensaje tipo 2), el hilo de escucha captura la trama y extrae el identificador xid.

4. Verifica si el xid se encuentra listado en el diccionario local `active_xids`. Si no coincide, ignora el paquete (evitando interactuar con solicitudes de hosts ajenos al laboratorio).
5. Extrae la IP ofrecida (`yiaddr`) y evalúa mediante la librería `ipaddress` si pertenece al rango objetivo vIOS (192.168.89.1 - 192.168.89.149).
6. Si la IP se encuentra fuera de estos límites (por ejemplo, si pertenece al rango configurado para el posterior ataque de suplantación), el script descarta la oferta para no mermar su propio espacio operativo.

Fase 4: Confirmación y Secuestro del Direccionamiento

1. Si la oferta es válida, la función `build_dhcp_request()` genera de inmediato un paquete DHCP REQUEST apuntando explícitamente a la IP del servidor que ofertó (`server_id`) y a la dirección física aleatoria originaria de la transacción.
2. Tras la transmisión del paquete, el script espera el acuse de recibo final (DHCP ACK, Mensaje tipo 5).
3. Al recibir el ACK, se registra la IP como "robada" dentro del diccionario `leases` y se remueve el identificador xid de la lista activa.
4. El proceso se repite de manera cíclica hasta que la función `pool_exhausted()` dictamine que la cantidad de registros en `leases` es igual al total de IPs del segmento atacado, deteniendo la ejecución y notificando que el espacio está listo para la fase de spoofing.

6. Documentación de Contra-medidas

Para mitigar el riesgo de denegaciones de servicio por agotamiento de tablas de direccionamiento dinámico, se aplican controles de acceso en la capa de enlace de datos:

A. Port Security (Seguridad de Puertos a nivel Switch)

Es la solución directa más eficiente contra herramientas automatizadas que alteran tramas de Capa 2.

- El administrador limita la cantidad máxima de direcciones MAC de origen que pueden registrarse o transitar a través de un único puerto físico del switch (normalmente restringido a un máximo de 1 o 2 MACs para bocas de acceso de usuarios finales).

- En cuanto el script envíe la segunda o tercera trama con una dirección física aleatoria distinta a la real de la tarjeta, el switch detectará una violación de la política, descartará las tramas de forma inmediata y, dependiendo de la configuración (shutdown), deshabilitará el puerto físico del atacante por completo.

B. DHCP Snooping Limit Rate

Complementando la verificación de servidores válidos analizada en laboratorios anteriores, la función de DHCP Snooping permite restringir la tasa de transferencia de paquetes DHCP permitidos por segundo en puertos catalogados como no confiables (untrusted ports)

Si un puerto de usuario comienza a transmitir tramas Discover de forma masiva (como el flujo impuesto por los parámetros PACKET_DELAY y BURST_SIZE de este script), el switch superará el umbral permitido configurado (ej. máximo 15 paquetes DHCP por segundo) e ingresará el puerto en un estado de error (err-disable), mitigando el ataque de forma automatizada.

C. IP Source Guard (IPSG)

Mecanismo de seguridad que trabaja en conjunto con la base de datos de vinculación creada por el DHCP Snooping. Impide que un equipo transmita tráfico IP empleando una dirección IP o MAC distinta a la asignada legítimamente en su proceso de negociación inicial, neutralizando los intentos del script de suplantar identidades de red de forma masiva desde una sola conexión física.